DIRECTIVE SUR LA GOUVERNANCE, LE RISQUE ET LA CONFORMITÉ EN SÉCURITÉ DE L'INFORMATION

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
   1.1. Portée 3
   1.2. Contexte 3
   1.3. Définitions 3
2. Exigences de la directive 4
   2.1. Exigences relatives à la gestion des actifs informationnels 4
   2.2. Exigences relatives à la gouvernance de la sécurité de l'information 5
   2.3. Exigences relatives à la stratégie et à la planification de la sécurité 6
   2.4. Exigences relatives à la gestion des tiers 6
   2.5. Exigences relatives à l'évaluation et à la gestion du risque 7
   2.6. Exigences relatives à la conformité de la sécurité de l'information 8
3. Écarts et exceptions 9

Directive sur la gouvernance, le risque et la conformité en sécurité de l'information	
Propriétaire	Chef de la sécurité de l'information (CISO)
Portée	Groupe
Objectif de la Directive	Établir les exigences en matière de gouvernance de la sécurité de l'information, de gestion du risque et de la conformité dans au sein de iA Groupe financier.
Date de révision	s.o.
Autorité d'approbation	Comité directeur sur la sécurité de l'information (CDSI)
Date d'approbation	7 avril 2022
Date d'entrée en vigueur	7 avril 2022
Fréquence de révision	Tous les trois (3) ans ou à la suite de changements majeurs
Prochaine révision	2025-04

1. Introduction

1.1. Portée

La *Directive sur la gouvernance, le risque et la conformité en sécurité de l'information* s'applique à iA Groupe financier, à ses employés, à ses fournisseurs de services et à ses sous-traitants, consultants et toute personne dont le travail est sous la responsabilité de la direction de la Société, sur laquelle la Société exerce un contrôle direct et qui utilise les actifs de iA Groupe financier.

1.2. Contexte

Les organisations doivent établir un cadre complet et approuvé de gouvernance, de gestion du risque et de la conformité en sécurité de l'information afin de définir une orientation claire pour la sécurité de l'information et d'identifier de manière proactive les principaux risques et les exigences de conformité, de les évaluer et de les gérer de manière adéquate.

L'objectif de cette directive est de s'assurer que les exigences entourant la gouvernance de la sécurité de l'information, la stratégie, la gestion du risque et de la conformité sont définies et alignées sur la politique de gestion des risques opérationnels afin de prévenir l'apparition d'incidents perturbateurs pouvant affecter les informations et les parties prenantes de la Société.

1.3. Définitions

Un « *actif informationnel* » désigne une information considérée comme un actif ayant une valeur reconnue (par exemple, un système d'information, une application, un matériel, un document). L'actif informationnel peut désigner à la fois l'information (le contenu, soit l'actif de données) et l'actif TI traitant l'information (le contenant, soit l'actif TI).

Le « *Comité directeur de la sécurité de l'information (CDSI)* » est un comité mis en place par le Chef de la sécurité de l'information (CISO) pour assurer une gouvernance stratégique et une supervision adéquate de la fonction de sécurité de l'information.

Une « exigence de conformité » est une exigence à laquelle une organisation doit se conformer.

Les « *fournisseurs* » font référence aux fournisseurs de services, intégrateurs, vendeurs, télécommunications et support d'infrastructure qui sont externes à l'organisation.

La « *gouvernance de la sécurité de l'information* » désigne un système par lequel les activités de sécurité de l'information d'une organisation sont dirigées et contrôlées.

« *iA Groupe financier » ou « la Société* » désigne iA Société financière inc. et ses filiales directes et indirectes, exerçant leurs activités sous le nom iA Groupe financier.

Une « *information confidentielle* » désigne l'information qui ne doit être communiquée ou rendue accessible qu'aux personnes et aux entités autorisées. On parlera plus spécifiquement d'une « information critique » lorsqu'une information confidentielle a le potentiel de mettre en péril l'intégrité de la personne ou de l'organisation qu'elle concerne.

Le « *nettoyage* » désigne les mesures prises pour rendre les données écrites sur des supports irrécupérables par des moyens ordinaires et, pour certaines formes d'assainissement, extraordinaires.

Un « *niveau de service* » désigne la définition des attentes entre le fournisseur de services et le client et la description des produits ou services à livrer, du point de contact unique pour les problèmes de l'utilisateur final, et des mesures par lesquelles l'efficacité du processus est surveillée et approuvée.

Un « *propriétaire d'actif* » est un rôle organisationnel responsable de la gestion, de l'utilisation et de la protection d'un actif. Pour les actifs de données, cette responsabilité est assignée à un « responsable de données ».

Le ou les « *risque(s) opérationnel(s)* » s'entend(ent) du risque d'encourir des pertes découlant de lacunes ou d'erreurs attribuables aux processus, aux personnes, aux systèmes ou à des événements externes, incluant le risque réglementaire et excluant le risque stratégique.

Les « *tiers* » désignent les entités externes telles que les fournisseurs, les partenaires du côté de l'offre et du côté de la demande, les alliances, les consortiums et les investisseurs. Il peut s'agir de parties contractuelles et non contractuelles.

La « *tolérance au risque* » désigne le degré auquel une entité, un actif, un système, un réseau ou une zone géographique est prêt à accepter le risque.

2. Exigences de la directive

2.1. Exigences relatives à la gestion des actifs informationnels

De nombreuses organisations doivent relever le défi de gérer des environnements complexes et en constante évolution. Cependant, les attaquants, qui peuvent être situés n'importe où dans le monde, ont démontré leur capacité, leur patience et leur volonté d'inventorier et de comprendre les actifs des

organisations à grande échelle afin de soutenir leurs possibilités d'attaque. Par conséquent, la Société doit gérer activement tous les actifs informationnels qu'elle possède ou utilise afin que seuls les actifs autorisés soient présents dans son environnement informatique et puissent y accéder. Les exigences nécessaires à la gestion des actifs informationnels sont énumérées ci-dessous.

a. S'assurer que tous les actifs informationnels utilisés par l'entreprise sont identifiés et ont un propriétaire (ou un responsable, dans le cas des actifs de données) désigné.
b. S'assurer que tous les actifs critiques sont classés selon les schémas de classification et de catégorisation de la Société.
c. Tenir des registres d'inventaire précis, complets et à jour de tous les actifs informationnels identifiés.
d. S'assurer que l'utilisation acceptable de tous les actifs informationnels de l'inventaire est définie et documentée et que les actifs informationnels sont protégés pendant le transport hors du contrôle de la Société.
e. Disposer des actifs en toute sécurité lorsqu'ils ne sont plus nécessaires, en utilisant des procédures formelles de destruction et de nettoyage pour minimiser le risque de fuite d'informations confidentielles vers des personnes non autorisées.

2.2. Exigences relatives à la gouvernance de la sécurité de l'information

La croissance des données, les nouvelles technologies et l'évolution des cybermenaces posent de nombreux défis aux organisations pour protéger leurs informations. La gouvernance de la sécurité de l'information permet à la Société de disposer d'une structure d'information, d'un leadership et de conseils appropriés pour relever ces défis. La Société doit mettre en œuvre et évaluer la gouvernance de la sécurité de l'information afin de s'assurer qu'un cadre adéquat est établi et que la direction de la Société fait preuve d'engagement pour mettre en œuvre, surveiller et orchestrer les besoins et les politiques de sécurité de l'information. Les exigences nécessaires à la gouvernance de la sécurité de l'information et à la mise en œuvre du programme de sécurité de l'information de la Société sont énumérées ci-dessous.

a. Établir un cadre normatif de la sécurité de l'information sous la forme d'une politique, ainsi que des directives, des normes, des processus et des guides pour soutenir les objectifs de sécurité de l'information de la Société.
b. S'assurer qu'un Chef de la sécurité de l'information (CISO) est désigné pour superviser le déploiement du programme de sécurité de l'information de la Société.
c. Établir une structure organisationnelle de sécurité efficace pour mettre en œuvre le programme de sécurité de l'information dans l'ensemble de la Société.
d. Établir un comité directeur de la sécurité de l'information (CDSI) doté d'un mandat clair pour définir les objectifs de la stratégie de sécurité de l'information et superviser l'approche globale de la Société en matière de sécurité de l'information.
e. Établir un programme de sécurité de l'information qui détaille l'approche globale de la stratégie, de la gouvernance et de l'architecture de la sécurité de l'information.
f. S'assurer que la stratégie de sécurité de l'information est intégrée à la stratégie d'affaires et TI de la Société.
g. S'assurer que la stratégie en matière de sécurité de l'information est soutenue et approuvée par la haute direction.

h. Développer et maintenir un programme de formation et de sensibilisation à la sécurité de l'information afin d'éduquer toutes les personnes qui ont accès aux informations et aux actifs de la Société et s'assurer que les comportements responsables sont intégrés dans les activités quotidiennes des individus.
i. Évaluer et rendre compte des résultats par rapport aux objectifs prévus, représentés sous la forme d'indicateurs clés de performance mesurables.

2.3. Exigences relatives à la stratégie et à la planification de la sécurité

La Société doit articuler, gouverner et exécuter un plan stratégique pour maintenir le risque de sécurité de l'information dans des seuils acceptables et promouvoir la résilience de ses opérations en accord avec les objectifs de sécurité plus larges de l'entreprise. L'allocation stratégique des ressources et le développement d'une posture de sécurité répondant aux besoins de l'organisation doivent être intégrés à la stratégie d'affaires et TI globale de l'entreprise. Les exigences nécessaires pour soutenir les décisions stratégiques en matière de sécurité de l'information et la supervision de leur mise en œuvre au sein de la Société sont énumérées ci-dessous.

a. Établir la structure de gouvernance requise et attribuer les responsabilités en conséquence pour mettre en œuvre la stratégie et les initiatives de sécurité de l'information.
b. Démontrer comment la stratégie de sécurité de l'information prévue soutiendra les objectifs généraux de la Société en réduisant le risque opérationnel, le risque financier et le risque réputationnel.
c. Évaluer l'état actuel de la sécurité de l'information et définir un état cible réalisable qui favorise les objectifs et les besoins de la Société en matière de sécurité de l'information.
d. Identifier, prioriser et sélectionner la combinaison optimale d'investissements stratégiques en matière de sécurité de l'information nécessaires pour atteindre l'état cible dans les délais prévus.
e. Formuler des plans d'action opérationnels qui détaillent les objectifs, les équipes de travail, les étapes et les tests d'efficacité des initiatives de sécurité de l'information sélectionnées.
f. Affecter des ressources suffisantes et attribuer la propriété pour traiter le risque et les lacunes.
g. Contrôler l'efficacité et l'achèvement des initiatives de sécurité de l'information conformément au plan et intervenir si nécessaire pour maintenir les plans sur la bonne voie.
h. Recueillir et examiner les leçons apprises pour adapter les plans, la documentation, les communications et la formation futurs.

2.4. Exigences relatives à la gestion des tiers

Les organisations s'appuient continuellement sur des tiers pour assurer des services essentiels à leur mission, ce qui peut accroître le risque pour l'entreprise. Par conséquent, la Société doit identifier et gérer le risque lié à la sécurité de l'information à toutes les étapes de la relation avec ses tiers en intégrant des exigences de sécurité de l'information dans leurs ententes et en obtenant l'assurance qu'elles sont respectées. Cela peut contribuer à protéger les informations confidentielles de la Société lorsqu'elles sont traitées par des tiers ou lorsqu'elles sont transmises entre la Société et ses tiers. Les exigences nécessaires à la gestion des tiers au sein de la Société sont énumérées ci-dessous.

a. Tenir des registres précis et à jour de tous les tiers.

b. Effectuer un examen périodique de l'inventaire des tiers pour s'assurer que toutes les informations sont correctes et complètes.
c. S'assurer que le processus d'approvisionnement est documenté, qu'il inclut la définition des exigences en matière de sécurité de l'information et qu'il dispose d'un mécanisme permettant d'identifier les ententes et les fournisseurs présentant un niveau de risque plus élevé, notamment en matière de sécurité de l'information.
d. Effectuer une évaluation, basée sur des méthodologies acceptées par l'industrie, sur chaque tiers présentant un niveau de risque plus élevé, afin de vérifier qu'ils ne présentent pas de risque significatif pour les informations et les actifs informationnels de la Société.
e. Utiliser les résultats de l'évaluation pour affiner les termes et conditions clés des ententes afin de s'assurer que les informations et les actifs informationnels de la Société sont protégés de manière adéquate.
f. Traiter de la sécurité de l'information dans toutes les ententes pertinentes conclues avec des tiers.
g. Effectuer des évaluations périodiques des tiers en utilisant des audits, des examens de performance par rapport aux accords de niveau de service établis, ou d'autres formes d'évaluation pour confirmer que leurs obligations contractuelles sont respectées et que le risque associé aux tiers pour l'entreprise est sous contrôle.
h. Établir une méthode cohérente pour la transition de sortie ou le renouvellement des ententes avec les tiers.

2.5. Exigences relatives à l'évaluation et à la gestion du risque

Les organisations sont souvent confrontées à des forces perturbatrices qui peuvent accroître le risque lié aux technologies de l'information et à la sécurité (ci-après « le risque TI »). Ces forces peuvent être des paysages de menaces changeants, des changements dans les activités, des technologies en développement ou des mises à jour de la conformité réglementaire. Par conséquent, la Société doit mettre en œuvre un processus de gestion du risque qui soit reproductible et systématique pour identifier, analyser et évaluer le risque TI. Les exigences nécessaires à l'établissement d'une approche de gestion du risque TI dans les limites des tolérances fixées dans la « Politique de gestion des risques opérationnels » sont énumérées ci-dessous.

a. S’assurer de la nomination d'un chef de la gestion des risques (CRO) chargé de surveiller l'état des risques majeurs pour la Société, y compris le risque TI, et de s'assurer que des ressources sont fournies et affectées de manière appropriée pour faire face au risque.
b. S'assurer que la méthodologie de gestion du risque TI a une terminologie et des cotes de risque communes avec les autres cadres de l’organisation et qu'elle est élaborée en adaptant les méthodologies existantes et en les personnalisant pour répondre aux besoins de la Société en matière de gestion du risque.
c. S'assurer que le processus et le cadre formalisés de gestion du risque TI définissent un processus cohérent d'identification, d'analyse, d'évaluation, d'escalade et de traitement du risque TI, conformément aux objectifs d’affaires de la Société et aux procédures de tolérance au risque et d'escalade.

d. Effectuer régulièrement des évaluations du risque TI pour une série d'environnements cibles critiques catégorisés, y compris les processus d'affaires, les applications d'affaires et les systèmes et réseaux de soutien.
e. Élaborer et tenir à jour une liste complète et pertinente des menaces et des contrôles qui intègre les résultats des évaluations des contrôles de sécurité lors de l'examen de l'efficacité des contrôles par rapport aux menaces.
f. Appliquer le cadre de gestion du risque dans les activités d'établissement du contexte et d'évaluation, de traitement, de communication, de surveillance et de révision du risque.
g. Concevoir et mettre en œuvre un plan d'action pour remédier à la situation pour chaque risque résiduel dépassant la tolérance au risque de l'entreprise.
h. Communiquer l'état, les exigences et le calendrier du plan de traitement du risque aux parties prenantes concernées.
i. Établir un registre de risque comprenant les résultats de l'évaluation du risque qui doit être maintenu, surveillé et utilisé pour suivre de manière centralisée tout risque évalué.

2.6. Exigences relatives à la conformité de la sécurité de l'information

La Société doit établir ses exigences de conformité en matière de sécurité de l'information en fonction de ses exigences légales, réglementaires et contractuelles, des meilleures pratiques mises en évidence dans les normes du secteur ainsi que des politiques, normes, directives et procédures de l'organisation. En outre, la Société doit s'assurer que les contrôles de sécurité de l'information sont systématiquement classés par ordre de priorité afin de répondre à ces exigences. Les exigences nécessaires pour assurer la conformité aux obligations légales, réglementaires et contractuelles applicables à la Société, aux normes de l'industrie ainsi qu'aux politiques, normes et procédures de l'entreprise en matière de sécurité de l'information sont énumérées ci-dessous.

a. Tenir des registres précis et à jour de toutes les exigences de conformité en matière de sécurité de l'information. La liste des exigences est établie à partir des exigences légales, réglementaires et contractuelles pertinentes en matière de sécurité, des meilleures pratiques mises en évidence dans les normes de l'industrie ainsi que des politiques, normes et procédures organisationnelles.
b. Traduire les exigences de conformité en matière de sécurité de l'information en clauses qui peuvent être suivies et inclure des exemples de preuves à fournir pour faciliter un examen précis et rapide. Ces clauses doivent être fixées dans des documents-cadres tels que des politiques, des directives et des normes.
c. S'assurer que les propriétaires de processus ou d'actif :

    - Comprennent les exigences de conformité en matière de sécurité de l'information, évaluent l'impact sur le processus ou l'actif sous leur responsabilité et mettent en œuvre les contrôles nécessaires pour répondre à ces exigences.
    - Identifient et traitent les écarts de conformité ou les cas de non-conformité.
    - Remplissent une demande de dérogation lorsque les exigences de conformité en matière de sécurité de l'information ne sont pas respectées pour le processus ou l'actif informationnel sous leur responsabilité.

d. S'assurer que le chef de la sécurité de l'information supervise le respect des exigences de conformité en matière de sécurité de l'information et obtient l'assurance que les contrôles en place sont efficaces pour répondre à ces exigences.
e. S'assurer que les activités d'audit et de conseil internes fournissent une assurance indépendante et objective conçue pour ajouter de la valeur et améliorer les opérations de la Société liées à la sécurité de l'information.

3. Écarts et exceptions

Dans les cas où cette directive n'est pas respectée, une demande de dérogation doit être remplie en suivant le processus de dérogation au cadre normatif de sécurité de l'information.

Veuillez contacter l'équipe de sécurité de l'information < *DemandesSecuriteSI@ia.ca* > pour obtenir plus d'informations sur ce processus ou sur la directive, le cas échéant.